



Weekly Cyber Threat Intelligence Report

Reporting window: 2 - 9 June 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary

8

Critical CVEs

5

High-sev issues

4

Actively exploited

6

Notable breaches

7

PoCs / tools

13

IOCs to add

This week was dominated by **software supply-chain worms** and **edge-device zero-days feeding ransomware**. Self-propagating campaigns (Shai-Hulud / Mini Shai-Hulud, IronWorm / Miasma) hit both npm and PyPI - including 73 Microsoft GitHub repositories and 19 trojanised science PyPI packages that execute the moment Python starts. A Check Point Remote Access VPN zero-day was exploited and linked to the **Qilin** ransomware gang, while critical RCEs landed in nginx, Gogs, UniFi OS, LiteLLM and two WordPress plugins. **AI/LLM infrastructure** is now a first-class target. Regionally, third-party / vendor breaches struck APAC (SoFi Hong Kong) and Australia (R.I.C. Publications; an Australian mortgage dataset for sale). **Items below are ordered verified-first**; public PoCs/exploit releases and indicators to add to blocklists/SIEM are called out in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & data

Australian mortgage company - 5,000 sensitive profiles for sale

HIGH

UNVERIFIED

Breach

Finance

A threat actor is advertising ~5,000 profiles allegedly stolen from an unnamed Australian mortgage company, including highly sensitive financial and identity documents. High fraud / identity-theft potential. Reported by @DarkWebInformer.

R.I.C. Publications (AU educational publisher) - alleged data leak

MEDIUM

UNVERIFIED

Breach

Education

Threat actor "2019" is distributing an alleged dataset from R.I.C. Publications, an Australian educational publishing company. Scope unconfirmed; monitoring for validation.

APAC - SPECIFIC

Regional incidents & actors

SoFi Hong Kong - third-party vendor data breach

HIGH

UNVERIFIED

Breach

Fintech

Hong Kong

SoFi Hong Kong confirmed a breach after attackers accessed a third-party vendor database holding customer information. Reinforces the regional vendor/sub-processor compromise pattern; customers face phishing and fraud risk.

Ref: bleepingcomputer.com

Yellow.co.nz (New Zealand) - ~237k records advertised

MEDIUM

UNVERIFIED

Breach

New Zealand

Carry-over regional exposure: an actor is advertising ~237,000 records from the NZ business directory Yellow.co.nz (business contacts + platform data). Useful for BEC / supply-chain targeting across ANZ.

DPRK Lazarus & China-attributed TeamPCP - active in region

WATCH

UNVERIFIED

APT

DPRK

China

APAC-origin state actors remain busy: Lazarus (signed-driver BYOVD, Zoom lures, macOS "Mach-O Man" C-level targeting) and TeamPCP, which open-sourced the Mini Shai-Hulud supply-chain framework now used more widely.

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs					Patch now
Check Point Remote Access VPN zero-day - exploited, linked to Qilin					
CRITICAL	UNVERIFIED	VPN	Ransomware	Exploited	
Emergency fix for a critical flaw in Check Point Remote Access VPN / Mobile Access, exploited as a zero-day and tied to the Qilin ransomware operation. Edge VPN remains the leading ransomware on-ramp.					
PoC: Active exploitation in the wild					
Ref: bleepingcomputer.com					
LiteLLM chained RCE - actively exploited in the wild					
CRITICAL	UNVERIFIED	AI/LLM	RCE	Exploited	
Attackers are exploiting a chained vulnerability in LiteLLM (open-source LLM gateway/proxy) to run arbitrary commands - exposing provider API keys and AI pipelines.					
PoC: Active exploitation in the wild					
Ref: cybersecuritynews.com					
WordPress Everest Forms Pro (CVE-2026-3300) - exploited					
CRITICAL	UNVERIFIED	WordPress	RCE	Exploited	
Active exploitation enabling full takeover of WordPress sites running Everest Forms Pro (admin creation, web shell). Patch to v1.9.13+.					
PoC: Active exploitation in the wild					
Ref: bleepingcomputer.com					
nginx "Rift" CVE-2026-42945 + PoolSlip - full RCE on default nginx					
CRITICAL	UNVERIFIED	Web	RCE		
Chained nginx RCE achieving full remote code execution on a default nginx 1.30.0 install. Internet-facing web tier risk; upgrade to 1.30.4 / 1.31.3.					
PoC: Public - Rift + PoolSlip chain published - x.com					
Ref: x.com					
Gogs critical zero-day RCE					
CRITICAL	UNVERIFIED	Git	RCE	ZeroDay	
Self-hosted Gogs Git service patched a critical zero-day allowing compromise of internet-facing instances and access to any repo (incl. private) - source & CI-secret exposure.					
Ref: bleepingcomputer.com					
UniFi OS - unauthenticated root RCE (3 chained)					
CRITICAL	UNVERIFIED	Appliance	RCE	PreAuth	
Three fixed Ubiquiti UniFi OS flaws chain to pre-auth root RCE. Exposed consoles can yield control of the whole managed network. Patch and remove public exposure.					
Ref: bleepingcomputer.com					
WordPress Contest Gallery Pro CVE-2026-42680 - unauth privesc (CVSS 9.8)					
CRITICAL	UNVERIFIED	WordPress	PrivEsc		
Unauthenticated privilege escalation in Contest Gallery Pro <=29.0.1. Trivial to weaponise on exposed sites.					
Ref: x.com					

libinput CVE-2026-50292 - CRLF injection to root RCE (CVSS 9.8)

CRITICAL

UNVERIFIED

Linux

RCE

udev property injection via libinput CRLF handling escalates to root RCE on Linux. Patch to v1.30.4 / 1.31.3.

Ref: secalerts.co

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

Windows Search URI handler - NTLMv2 coercion (no CVE, no fix)

HIGH

VERIFIED

Windows

CredTheft

One click on a search: link coerces NTLMv2 hash theft - no malware, no download. Microsoft triaged "case-by-case"; the handler behaviour is unfixed. Block outbound SMB (445) and monitor search: invocations.

PoC: Public method - one-click NTLMv2 capture (Huntress) - huntress.com

Ref: huntress.com

Windows DNS Client RCE - CVE-2026-41096

HIGH

UNVERIFIED

Windows

RCE

Malicious DNS responses processed by the Windows DNS client can lead to code execution (PT-2026-40237). Relevant to rogue/MITM DNS; apply the Microsoft patch.

Ref: x.com

VMware Cloud Foundation - 3 stored XSS

HIGH

UNVERIFIED

Virtualisation

XSS

Broadcom disclosed three stored XSS flaws in VMware Cloud Foundation enabling malicious script injection into the management UI.

Ref: cybersecuritynews.com

HTTP/2 "Bomb" - remote DoS across major servers

HIGH

UNVERIFIED

Web

DoS

New HTTP/2 Bomb technique enables remote DoS against NGINX, Apache HTTPD, IIS, Envoy and Cloudflare.

PoC: Demonstrated - 32 GB RAM exhausted in ~20s

Ref: thehackernews.com

Microsoft Edge - remote code execution

HIGH

UNVERIFIED

Browser

RCE

RCE vulnerability addressed in Microsoft Edge; ensure browsers are auto-updating.

GLOBAL - SOFTWARE SUPPLY CHAIN

Worm wave

Shai-Hulud - 19 science PyPI packages / 37 poisoned wheels

CRITICAL

VERIFIED

PyPI

CredTheft

Trojanised PyPI packages (hundreds of thousands of downloads) steal developer secrets, with malware that runs at Python startup - before any import. Part of the Shai-Hulud / Mini Shai-Hulud (TeamPCP) lineage.

Ref: bleepingcomputer.com

IronWorm / Miasma - self-replicating npm worm

CRITICAL

VERIFIED

npm

Worm

Self-propagating npm worm (Rust payloads, eBPF rootkit, Tor C2) that hit 73 Microsoft GitHub repositories and exfiltrates AWS/GCP/AI-provider keys. Sub-2h CI/CD deployment observed.

Ref: thehackernews.com

parsimonius - malicious PyPI typosquat

MEDIUM

UNVERIFIED

PyPI

Typosquat

Typosquatting supply-chain package on PyPI; representative of the steady background rate of registry typosquats.

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code

PSSW100AVB - PowerShell reverse shells, 100% AV bypass

MEDIUM

UNVERIFIED

PoC

AV-Bypass

Public repo of PowerShell reverse shells achieving 100% AV bypass as of June 2026 (est. 2-5 day detection window). Useful for red teams; equally available to adversaries.

Ref: github.com

EDRChoker - Policy-QoS EDR-silencing red-team tool

MEDIUM

UNVERIFIED

PoC

EDR-Bypass

Open-source red-team tool that abuses Policy-Based Quality of Service (QoS) to block/silence EDR processes. Hunt for unexpected QoS policy creation targeting security agents.

Ref: cybersecuritynews.com

RedSun - public zero-day exploit repository

WATCH

UNVERIFIED

PoC

ZeroDay

FullDisclosure

An independent researcher released RedSun, a public repo containing exploit PoC code for one or more undisclosed vulnerabilities (reportedly out of frustration with vendor non-response, per @vxunderground). Expect opportunistic reuse - monitor for matching exploitation.

Ref: github.com

OnlyLANs.ai - prompt-injection wargame

INFO

UNVERIFIED

PoC

PromptInjection

Free interactive wargame for practising prompt-injection against an AI assistant guarding secrets - useful for upskilling defenders on LLM attack techniques.

Ref: onlylans.ai

GLOBAL - MALWARE & CAMPAIGNS**PowerShell XOR stager - CloudFlare-themed lure**

MEDIUM

VERIFIED

Stager

C2

PowerShell XOR stager delivered via a CloudFlare-authenticator lure; open directory confirmed on the C2. See IOC table for C2 IP/domain.

ClickFix - fake Claude / Codex installers via Google Sites

HIGH

UNVERIFIED

Phishing

AI-lure

Credential-stealing campaign impersonating popular AI coding tools, hosted on trusted Google Sites; ClickFix social engineering delivers an in-memory stealer.

Ref: cybersecuritynews.com

NFCShare Android malware via fake banking-app updates on GitHub

HIGH

UNVERIFIED

Android

Banking

New NFCShare variants pose as legitimate banking-app updates hosted on GitHub, targeting banking credentials / NFC data.

Ref: bleepingcomputer.com

NSO spyware - WhatsApp spear-phishing disrupted

HIGH

UNVERIFIED

Spyware

Targeted

WhatsApp disrupted NSO Group spear-phishing and is filing a contempt order. Targeted surveillance risk for high-profile individuals.

Ref: bleepingcomputer.com

Nimbus RAT - delivered via Teams + Google Drive in <20 min

MEDIUM

UNVERIFIED

RAT

LoTS

Living-off-trusted-services delivery chain abusing Microsoft Teams and Google Drive to drop Nimbus RAT rapidly.

Ref: cybersecuritynews.com

Solara/Yuta loader abuses DeepSeek to generate Roblox exploits

MEDIUM

UNVERIFIED

Loader

AI-abuse

Trojanised .NET loader leverages the DeepSeek LLM to generate Roblox Luau exploits - LLM-assisted malware development.

GLOBAL - NOTABLE BREACHES**University of Oxford - breach via Group GTI CareerConnect**

HIGH

UNVERIFIED

Breach

Education

UK

Oxford disclosed a breach after third-party provider Group GTI reported its CareerConnect platform was compromised - student/alumni/employer data exposure.

Ref: bleepingcomputer.com

Meta AI support abuse - 20,225 Instagram accounts hijacked

HIGH

UNVERIFIED

Breach

AI-abuse

Attackers abused Meta's AI-powered support system to reset passwords, hijacking 20,225 Instagram accounts - an AI-workflow abuse case study.

Ref: bleepingcomputer.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
193.111.117[.]6	IPv4 (C2)	PowerShell XOR stager - CloudFlare lure	bleepingcomputer.com
cloud-flare-authenticator[.]link	Domain (C2)	Open dir confirmed; same stager campaign	-

Indicator	Type	Context	Reference
CVE-2026-3300	CVE	WordPress Everest Forms Pro RCE (exploited); fix v1.9.13+	bleepingcomputer.com
CVE-2026-42945	CVE	nginx "Rift" + PoolSlip RCE on default 1.30.0; fix 1.30.4/1.31.3	x.com
CVE-2026-42680	CVE	WordPress Contest Gallery Pro <=29.0.1 unauth privesc (9.8)	x.com
CVE-2026-50292	CVE	libinput CRLF -> root RCE (9.8); fix 1.30.4/1.31.3	secalerts.co
CVE-2026-41096	CVE	Windows DNS Client RCE (PT-2026-40237)	x.com
search: URI handler	Technique	Windows Search NTLMv2 coercion (no CVE/fix)	huntress.com
Shai-Hulud (19 sci PyPI pkgs / 37 wheels)	Malicious packages	PyPI supply-chain; runs at Python startup	bleepingcomputer.com
IronWorm / Miasma (npm)	Worm / packages	npm supply-chain; 73 Microsoft GitHub repos	thehackernews.com
parsimonius (PyPI)	Malicious package	Typosquat supply-chain	-
Fake Claude/Codex installers (Google Sites)	Hosting / lure	ClickFix in-memory credential stealer	cybersecuritynews.com
NFCShare APKs (GitHub-hosted)	Malware / hosting	Fake banking-app updates (Android)	bleepingcomputer.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Self-propagating software supply-chain worms

Why it matters: Shai-Hulud/Mini Shai-Hulud, IronWorm/Miasma and TeamPCP are spreading across npm + PyPI, executing at install/startup and stealing CI/cloud secrets - now reaching Microsoft's own GitHub repos.

Watch for: dependency installs that execute on import/startup; unexpected outbound from build agents; new maintainer tokens; .pth / sitecustomize hooks.

HIGH

AI / LLM infrastructure as a first-class attack surface

Why it matters: LiteLLM RCE was exploited in the wild; Pyodide sandbox escape, HuggingFace LeRobot gRPC RCE and AI agents auto-finding 0-days show the AI stack is now squarely in scope.

Watch for: exposed LLM gateways/proxies; unauthenticated model-serving endpoints; API-key sprawl on AI hosts.

HIGH

Edge / appliance zero-days feeding ransomware

Why it matters: Check Point VPN -> Qilin this week continues the pattern (UniFi, Cisco SD-WAN, Ivanti). Perimeter devices remain the fastest path from zero-day to ransomware.

Watch for: unpatched VPN/firewall/console firmware; anomalous VPN logins; new local admin accounts on appliances.

MED

AI-tool impersonation + trusted-platform abuse for delivery

Why it matters: Fake Claude/Codex installers on Google Sites & GitHub, ClickFix, and DeepSeek-assisted loaders weaponise trust in AI tooling and reputable hosts.

Watch for: users fetching 'AI tool' installers from non-official domains; ClickFix-style clipboard/run prompts.

MED

Malware-free credential coercion (NTLM)

Why it matters: The Windows Search search: URI handler enables one-click NTLMv2 theft with no CVE or fix - low-noise initial access / relay.

Watch for: outbound SMB (TCP 445) to external hosts; search: protocol handler invocations.

MED

Vendor/third-party breaches concentrating in AU/APAC

Why it matters: SoFi HK (vendor), Oxford (GTI), R.I.C. Publications and an AU mortgage dataset all trace to third-party/sub-processor exposure.

Watch for: third-party DB access scope; data shared with sub-processors; breach-notification clauses in vendor contracts.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Check Point RA VPN/Mobile Access; nginx -> 1.30.4/1.31.3; UniFi OS; Gogs; WordPress Everest Forms Pro (1.9.13+) & Contest Gallery Pro; libinput; Windows (DNS Client CVE-2026-41096, Edge).
Block IOCs	Add the IOC-table indicators (C2 IP/domain, malicious packages) to firewall/EDR/SIEM blocklists; alert on the listed CVEs.
Supply chain	Pin + hash-verify dependencies; scan for install/startup hooks; sandbox CI; rotate developer & CI/cloud secrets; review npm/PyPI installs from the last 2 weeks.
Identity & network	Block outbound SMB (445) egress; enforce MFA on all remote access; hunt for NTLM relay and anomalous VPN logins.
AI infrastructure	Inventory & restrict exposure of LLM gateways/proxies (LiteLLM); rotate provider API keys reachable from those hosts.
People & vendors	Brief staff on fake AI-tool installers and IT-support vishing; re-review third-party DB access / sub-processor data flows for AU/APAC entities.